S06 LAB REPORT

Network Scanning and Vulnerability Assessment

Kali Linux | Metasploitable 2 | Nmap

Programme: Digital Forensic & Cyber Security
Student name: Muhammad Latif
Cohort: PSEB-CYBER-ISB-02
ID: TRN-2026-000445
Date of practical: 9 November 2026
GitHub repository: digital-forensic-cyber-security-pseb-bootcamp

1. Introduction and Objectives

This report documents a hands-on network scanning and vulnerability assessment exercise. A Kali Linux machine was used to scan a deliberately vulnerable virtual machine (Metasploitable 2) with Nmap. The aim was to find out what the target exposes on the network, identify the software and versions behind each service, and record the weaknesses that an attacker could use.

All testing was done inside an isolated lab network, against a machine built to be vulnerable, for learning purposes only.

1.1 Objectives

By the end of this practical, the following were completed:

- Verify that the target system is reachable.
- Identify open ports.
- Detect running services and their versions.
- Perform basic service enumeration.
- Generate an Nmap report.

2. Lab Environment

Attacker machine	Kali Linux
Target machine	Metasploitable 2
Kali IP address	192.168.100.113 (netmask 255.255.255.0)
Target IP address	192.168.100.114 (netmask 255.255.255.0)
Target MAC address	B2:21:93:FA:1A:78
Tool	Nmap 7.99
Scope	Identify open ports, services and vulnerabilities on the single target host 192.168.100.114

3. Connectivity Verification

3.1 Checking IP addresses

The command below displays the network interface configuration, including the IP address, MAC address and network settings. It was run on both the attacker (Kali) and the target (Metasploitable) to confirm their addresses.

```
ifconfig
```

Kali's eth0 interface has the address 192.168.100.113, and Metasploitable's eth0 interface has 192.168.100.114. Both are on the same 192.168.100.0/24 network.

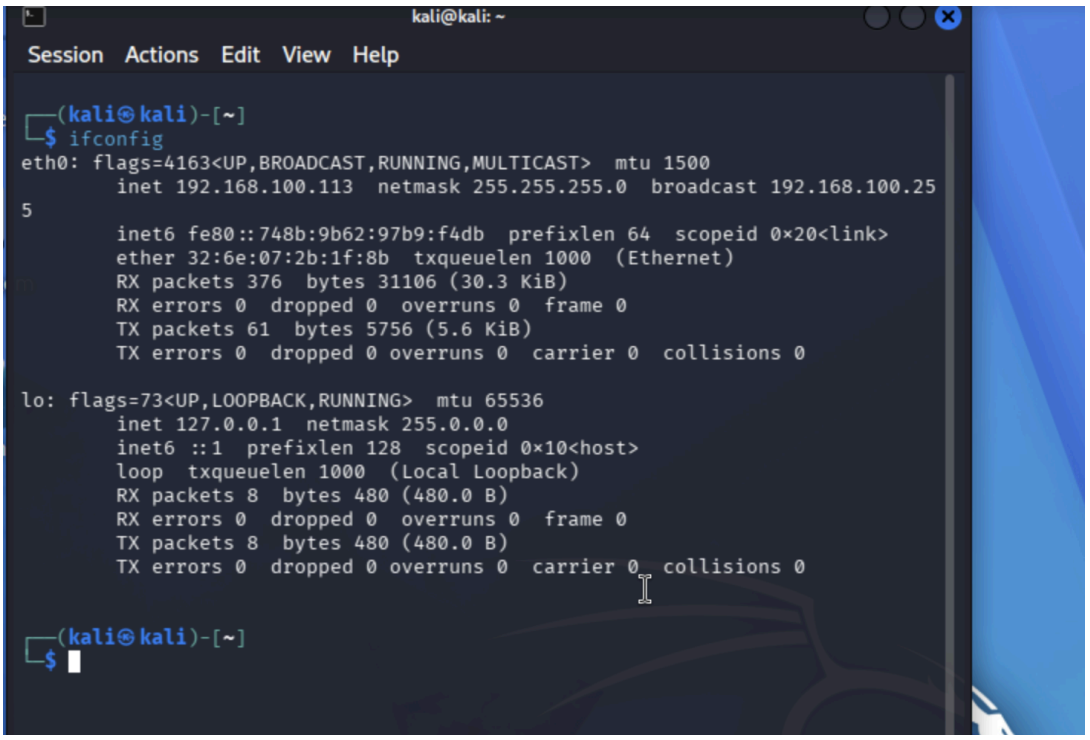


Figure 1: *ifconfig on Kali Linux (attacker): eth0 = 192.168.100.113.*

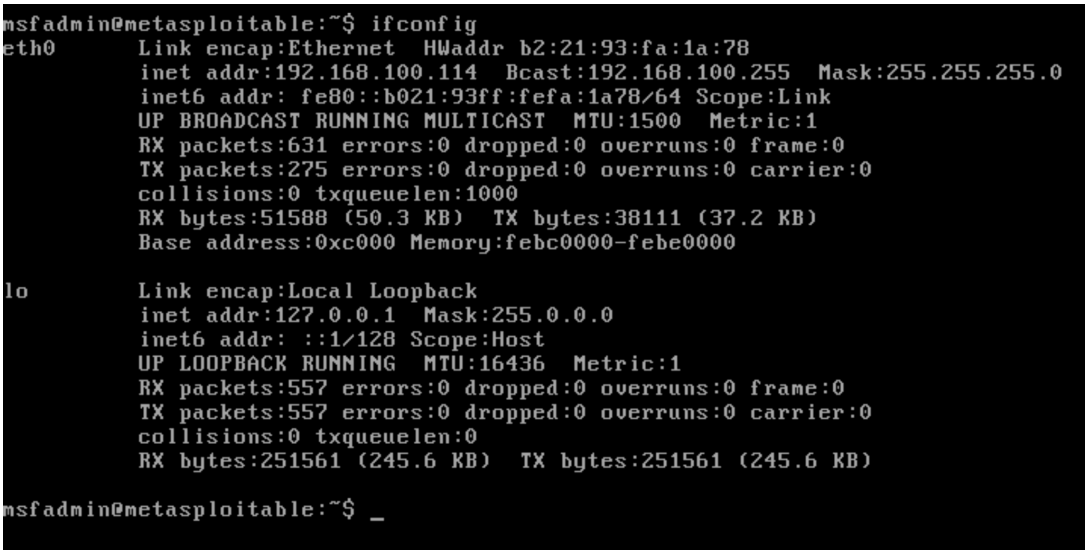


Figure 2: *ifconfig on Metasploitable 2 (target): eth0 = 192.168.100.114.*

3.2 Checking reachability

The ping command sends ICMP Echo Request packets to the target and confirms it is reachable and responding.

```
ping 192.168.100.114
```

The target replied to every request with a round-trip time of roughly 1 to 4 ms and a TTL of 64 (typical of a Linux system). The target is reachable, so scanning can proceed.

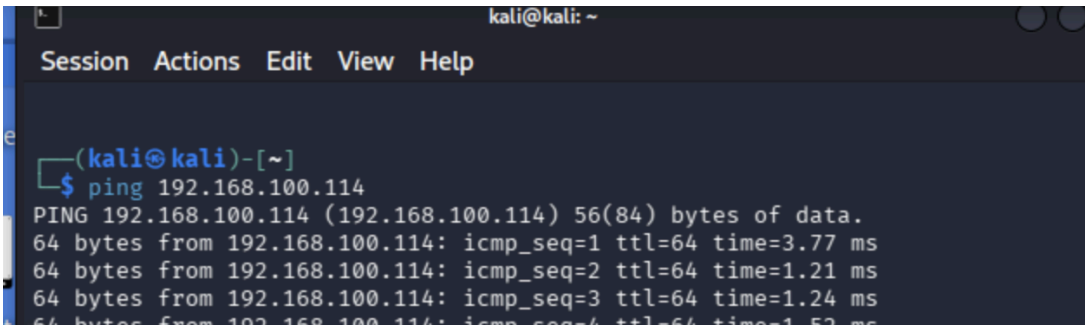


Figure 3: *Successful ping replies from 192.168.100.114.*

4. Nmap Scanning

4.1 Service version detection

This scan probes each open port and reports the name and version of the software behind it. Old versions are easier to match against known vulnerabilities.

```
sudo nmap -sV 192.168.100.114
```

Nmap reported the host as up. Of the 1,000 ports scanned, 23 were open and 977 were closed. The open ports and detected services are listed below.



Figure 4: *Output of nmap -sV showing open ports and service versions.*

Port	Service	Version detected
21/tcp	ftp	vsftpd 2.3.4
22/tcp	ssh	OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp	telnet	Linux telnetd
25/tcp	smtp	Postfix smtpd
53/tcp	domain	ISC BIND 9.4.2
80/tcp	http	Apache httpd 2.2.8 ((Ubuntu) DAV/2)

Port	Service	Version detected
111/tcp	rpcbind	2 (RPC #100000)
139/tcp	netbios-ssn	Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp	netbios-ssn	Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp	exec	netkit-rsh rexecd
513/tcp	login	OpenBSD or Solaris rlogind
514/tcp	tcpwrapped	(not identified)
1099/tcp	java-rmi	GNU Classpath grmiregistry
1524/tcp	bindshell	Metasploitable root shell
2049/tcp	nfs	2-4 (RPC #100003)
2121/tcp	ftp	ProFTPD 1.3.1
3306/tcp	mysql	MySQL 5.0.51a-3ubuntu5
5432/tcp	postgresql	PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp	vnc	VNC (protocol 3.3)
6000/tcp	X11	(access denied)
6667/tcp	irc	UnrealIRCd
8009/tcp	ajp13	Apache Jserv (Protocol v1.3)
8180/tcp	http	Apache Tomcat/Coyote JSP engine 1.1

Several of these are outdated or risky by design, including vsftpd 2.3.4, Apache 2.2.8, OpenSSH 4.7p1, MySQL 5.0.51a, telnet, and a service on port 1524 that Nmap identified as a "Metasploitable root shell".

4.2 Operating system detection

This scan tries to identify the target's operating system by analysing how it responds to network packets (TCP/IP stack fingerprinting). It needs root privileges, so sudo is used.

```
sudo nmap -O 192.168.100.114
```

Nmap identified the device as a general-purpose Linux machine running Linux kernel 2.6.9 to 2.6.33, one network hop away. This is a very old kernel and matches the expected Metasploitable 2 system.

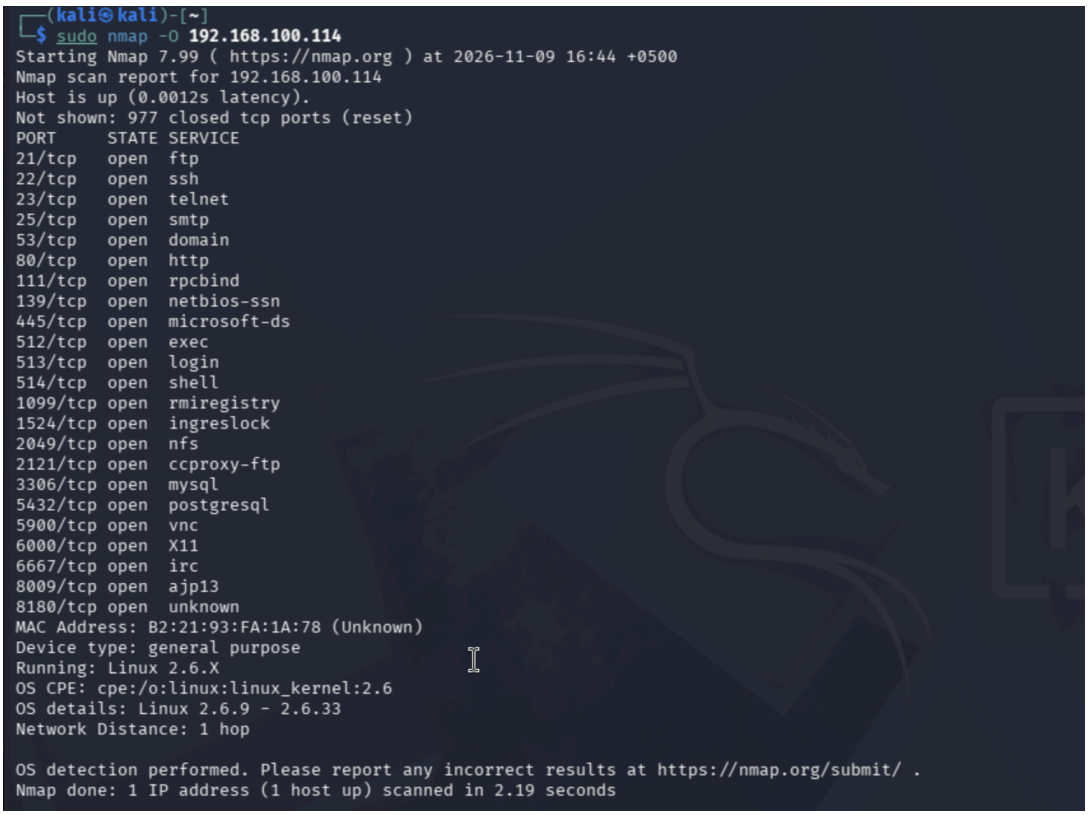


Figure 5: *Output of nmap -O: Linux 2.6.9 - 2.6.33, network distance 1 hop.*

4.3 Basic service enumeration (default scripts)

The -sC option runs Nmap's default scripts, which collect extra information from each service.

```
sudo nmap -sC 192.168.100.114
```

Key results from the visible output:

- Port 21 (FTP): anonymous FTP login is allowed (FTP code 230). The server banner shows vsFTPd 2.3.4, and the control and data connections are plain text.
- Port 22 (SSH): host keys are a 1024-bit DSA key and a 2048-bit RSA key.
- Port 25 (SMTP): the SSL certificate is valid only from 17 March 2010 to 16 April 2010, so it has long expired. SSLv2 is supported with weak ciphers (such as RC4, DES and MD5-based suites).
- Port 53 (DNS): BIND version 9.4.2 is disclosed.
- Port 80 (HTTP): the page title is "Metasploitable2 - Linux".

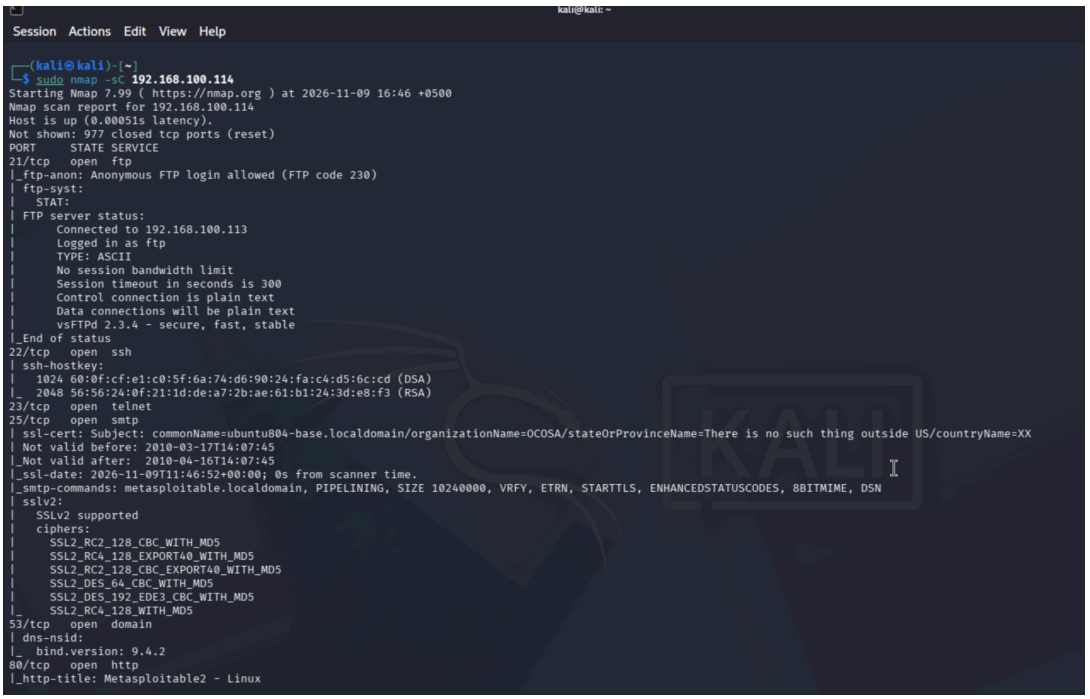


Figure 6: *Output of nmap -sC: default script results for ports 21 to 80.*

4.4 Saving the Nmap report

The -oN option saves the scan output in normal text format. The file can be kept as evidence and used in the vulnerability assessment report. Here it was combined with the version scan.

```
nmap -sV -oN report.txt 192.168.100.114
```



Figure 7: *Running nmap -sV -oN report.txt; the scan finished in 12.51 seconds.*

The saved file was then displayed with cat to confirm it was written correctly. It contains the full scan result with the Nmap start and finish times.

```
cat report.txt
```

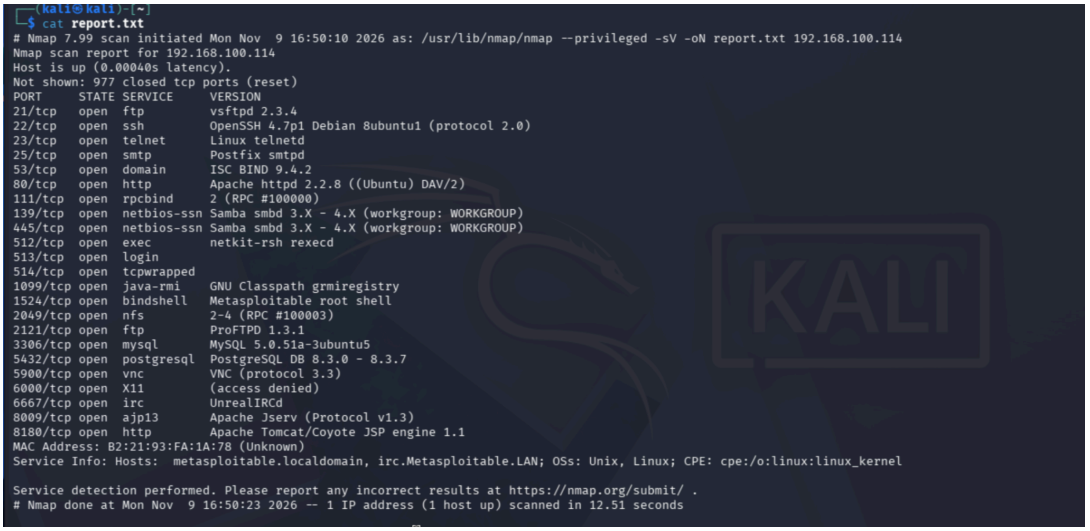


Figure 8: *Contents of report.txt, the saved Nmap report.*

5. Task A: Vulnerability Findings

The findings below are based on the scan output and the manual checks performed against 192.168.100.114. Severity ratings are the student's assessment for this lab. Findings are limited to what the evidence shows.

ID	Finding	Port	Severity	Evidence
F-01	vsftpd 2.3.4 backdoor (CVE-2011-2523)	21/tcp	Critical	Figures 4, 7; Section 6
F-02	phpinfo.php information disclosure	80/tcp	Low to Medium	Figure 9
F-03	Anonymous FTP access	21/tcp	Medium	Figures 6, 10
F-04	Root shell service exposed	1524/tcp	High	Figures 4, 7
F-05	Weak SSLv2 and expired certificate on SMTP	25/tcp	Medium	Figure 6

Finding 01: vsftpd 2.3.4 Backdoor

Port / service	21/tcp, FTP (vsftpd 2.3.4)
Observed behaviour	Nmap service detection identified vsftpd 2.3.4. This exact version is known to contain a malicious backdoor (CVE-2011-2523). Per the student's notes, Nmap's backdoor script ran the id command on the target and returned uid=0(root) gid=0(root).
Severity assessment	Critical (CVSS 3.1 base score 9.8; see Section 6)
Potential impact	A remote, unauthenticated attacker can obtain a root-level command shell on the target, giving full control over its data and services.
Recommendation	Remove vsftpd 2.3.4 and install a clean, current version from a trusted source, verifying its signature. Disable FTP if it is not needed, and block unneeded ports with a firewall.

Finding 02: phpinfo.php Information Disclosure

Port / service	80/tcp, HTTP (Apache httpd 2.2.8)
Observed behaviour	The page's HTTP headers were requested with: curl -I http://192.168.100.114/phpinfo.php The server returned HTTP 200 OK. The headers identified Apache 2.2.8 and PHP 5.2.4. The phpinfo page, opened in a browser, exposed further details such as the operating system (Linux metasploitable 2.6.24-16-server), PHP build date, and configuration file paths under /etc/php5/cgi.
Severity assessment	Low to Medium. This confirms information disclosure only; it does not by itself show that the web server was compromised.
Potential impact	Exposed versions and configuration details help an attacker fingerprint the server and plan further attacks.
Recommendation	Remove phpinfo.php from public web directories or restrict it to authorized administrators. Do not expose detailed configuration information to unauthenticated visitors.

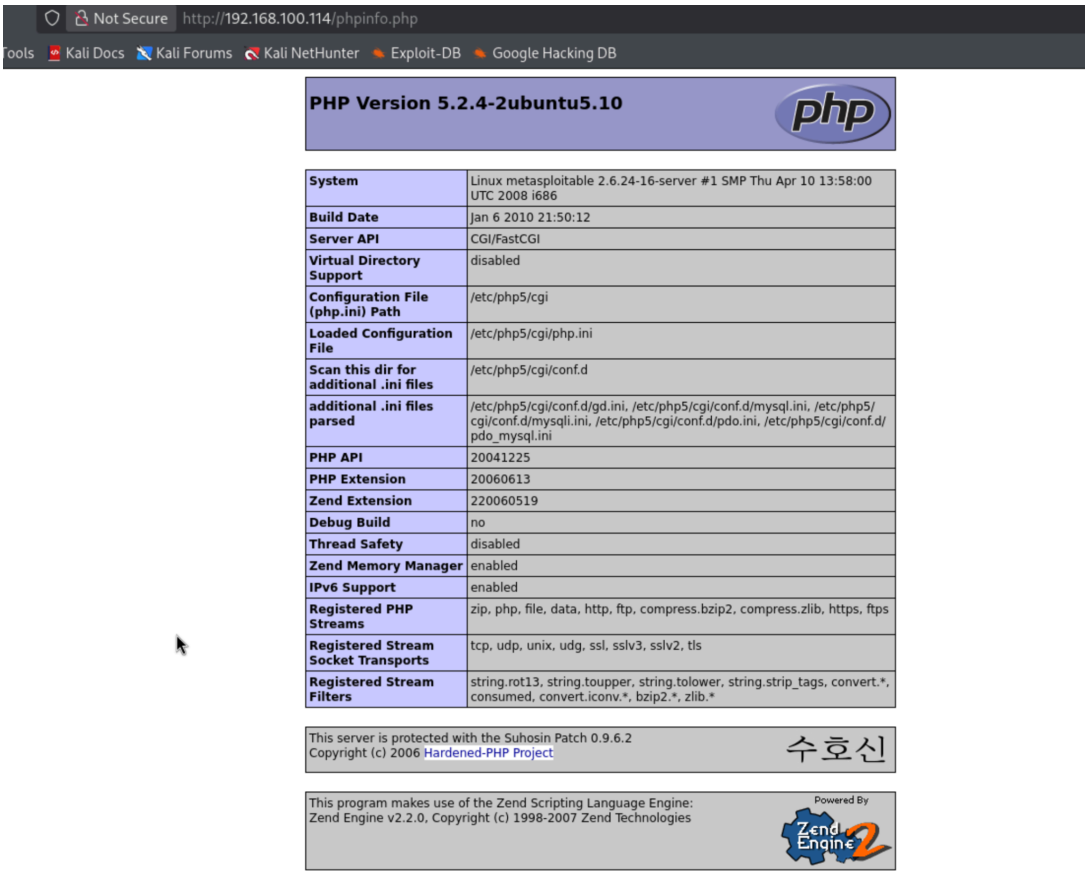


Figure 9: *phpinfo.php page showing PHP 5.2.4 and server configuration details.*

Finding 03: Anonymous FTP Access

Port / service	21/tcp, FTP (vsftpd 2.3.4)

Observed behaviour	The ftp client connected to the server. Login as the user "kali" failed (530 Login incorrect). Login as "anonymous" succeeded (230 Login successful). The working directory was reported as /, and the directory listing completed without showing any filenames.
Severity assessment	Medium. Anonymous authentication is confirmed, but no exposed files were seen in this test.
Potential impact	Anonymous access can expose files if they are present in the accessible directory and readable by anonymous users. No filenames were shown in this test.
Recommendation	Disable anonymous FTP unless explicitly required. If required, restrict the account to a dedicated directory and apply least-privilege permissions.

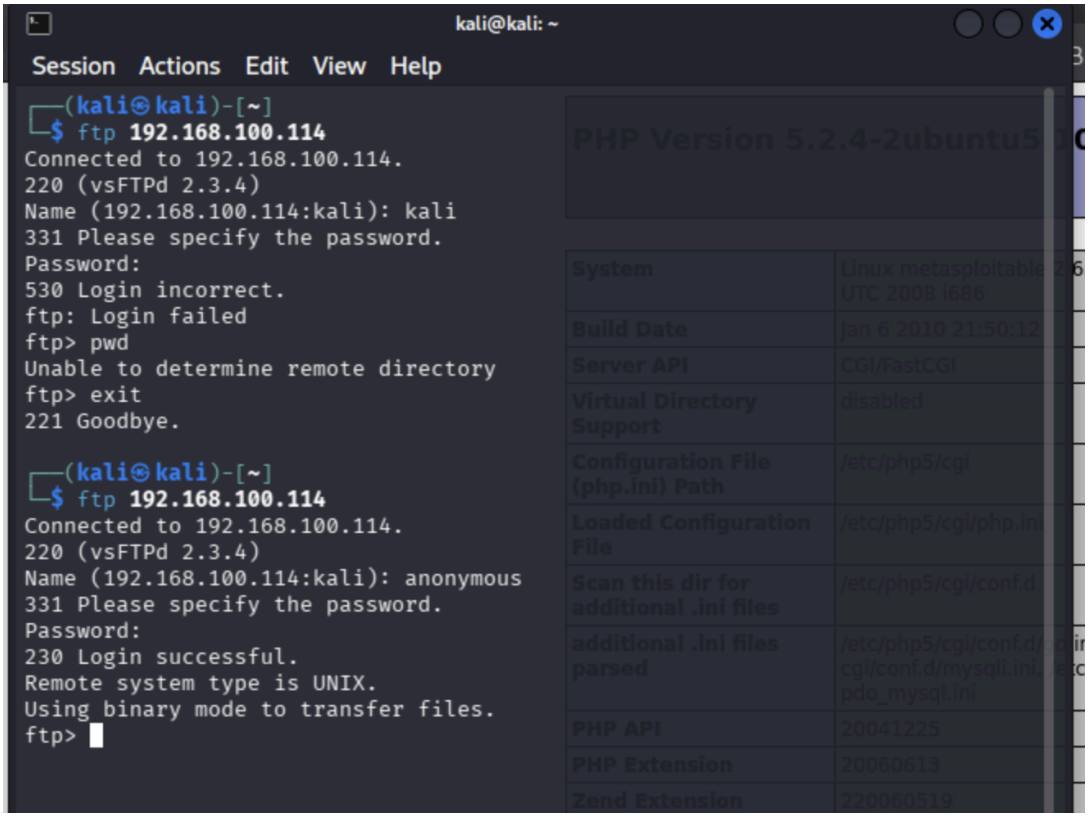


Figure 10: *FTP login: the user "kali" is rejected (530), while "anonymous" is accepted (230).*

Finding 04: Root Shell Service Exposed

Port / service	1524/tcp, bindshell
Observed behaviour	Nmap identified the service on port 1524 as "Metasploitable root shell". The service was not connected to or tested in this lab, so this finding is based on the service banner only.
Severity assessment	High
Potential impact	A shell service listening on the network can give an attacker direct command access without needing to exploit anything.
Recommendation	Stop and disable the service, remove the software that starts it, and block the port at the firewall.

Finding 05: Weak SSLv2 Support and Expired Certificate on SMTP

Port / service	25/tcp, SMTP (Postfix smtpd)
Observed behaviour	The Nmap default scripts showed that SSLv2 is supported with weak ciphers (RC2, RC4, DES, all with MD5). The certificate was valid only from 17 March 2010 to 16 April 2010.
Severity assessment	Medium
Potential impact	SSLv2 and the listed ciphers are obsolete and can be broken, so mail traffic could be intercepted or altered. An expired certificate cannot be trusted.
Recommendation	Disable SSLv2 and weak ciphers, allow only modern TLS versions, and install a valid, current certificate.

6. Task B3: CVSS Scoring

The following explanations decode the CVSS metric values for the vsftpd 2.3.4 backdoor (CVE-2011-2523) into plain English.

CVSS 3.1 vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Metric	Value	Interpretation
Attack Vector (AV)	N	The attacker can reach the vulnerable FTP service over a network.
Attack Complexity (AC)	L	The attack does not require unusual conditions or complicated preparation.
Privileges Required (PR)	N	The attacker does not need an existing account or prior privileges.
User Interaction (UI)	N	No action by another user is needed.
Scope (S)	U	The consequences remain within the security authority of the affected system.
Confidentiality (C)	H	Successful exploitation can expose sensitive information.
Integrity (I)	H	Successful exploitation can allow unauthorized modification of data.
Availability (A)	H	Successful exploitation can interrupt services or make the system unavailable.

Assessment

The vector describes a remotely reachable vulnerability that does not require prior authentication. The potential consequences affect confidentiality, integrity and availability. In the practical test, Nmap's backdoor script ran id and returned uid=0(root) gid=0(root), demonstrating root-level command execution on the target.

The published base scores are 9.8 under CVSS 3.1 and 10.0 under CVSS 2.0. The two versions use different metric systems, so their scores should not be treated as directly interchangeable.

Supporting notes (repository): evidence/task-b3-cvss-notes.md

References

NIST NVD, CVE-2011-2523:

https://nvd.nist.gov/vuln/detail/CVE-2011-2523

FIRST, CVSS v3.1 Specification:
https://www.first.org/cvss/v3.1/specification-document

FIRST, CVSS v2 Guide:
https://www.first.org/cvss/v2/guide

7. Task B6: vsftpd Supply-Chain Compromise

What happened?

In 2011, the official vsftpd download site was compromised and the vsftpd-2.3.4.tar.gz source archive was replaced with a modified version containing a malicious backdoor. Historical reporting described the compromised archive as available for approximately three days around the end of June and beginning of July 2011. This was a supply-chain attack because the software distribution process was tampered with.

The backdoor was designed to activate when an FTP login username contained the characters :) (a smiley face). After activation, it opened a shell on TCP port 6200, potentially allowing command execution on the affected machine. The issue is tracked as CVE-2011-2523.

How was it discovered?

Contemporary reporting credited Mathias Kresin with noticing the suspicious archive. Chris Evans, the vsftpd author, investigated and warned users that the download had been compromised. A failed detached GPG signature verification was an important indication that the archive could not be authenticated as an unmodified release.

Why is it relevant today?

The incident shows that trusting a software name or download location is not enough. If an attacker compromises a project's distribution site, users who download the tampered package may install malicious code. Modern systems depend on external packages, repositories, build systems and distribution services, so supply-chain risks remain relevant.

Ways to reduce the risk:

- Verify digital signatures and checksums before installing software.
- Obtain software from trusted sources.
- Keep software updated.
- Monitor for unexpected network services.
- Maintain an inventory of installed software.

Supporting notes (repository): evidence/task-b6-vsftpd-supply-chain.md

References

Chris Evans, Alert: vsftpd download backdoored (July 2011):
https://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html

The Register, Popular FTP package download tarball poisoned (5 July 2011):
https://www.theregister.com/security/2011/07/05/popular_ftp_package_download_tarball_poisoned/

NIST NVD, CVE-2011-2523:
https://nvd.nist.gov/vuln/detail/CVE-2011-2523

8. Conclusion

The target 192.168.100.114 was confirmed reachable with ping. Nmap found 23 open ports out of 1,000 scanned, and identified the services and versions behind them. OS detection showed an old Linux 2.6 kernel. The default script scan and manual checks showed several serious weaknesses, the most important being vsftpd 2.3.4, a version known to contain a backdoor that gives root access, and an exposed root shell service on port 1524. Other findings were anonymous FTP access, an exposed phpinfo page, and weak SSLv2 support with an expired certificate on SMTP.

The overall exposure of this machine is very high. This is expected, as Metasploitable 2 is intentionally vulnerable, but the same weaknesses (outdated software, unnecessary open services and unrestricted information) are common in real networks.